

****Serious Criticism of Signaturgruppen for Insufficient Security Regarding MitID****

Date: 23-06-2023

Decision

Private Companies

Serious Criticism

Supervision / Self-Initiated Case

Reported Breach of Personal Data Security

Processing Security

Unauthorized Access

Risk Assessment and Impact Analysis

The Data Protection Agency expresses serious criticism of both the Digitalization Agency and Signaturgruppen in a case where both parties shared responsibility for insufficient security in connection with login using MitID.

Journal Number: 2022-431-0171

****Summary****

In January 2022, several citizens experienced that when logging into their online bank via MitID, they gained access to other citizens' accounts. This was reported to the Data Protection Agency as a breach of personal data security by three financial institutions. This prompted the Data Protection Agency to initiate a case on its own accord to investigate the underlying problem.

The error turned out to be due to login requests to the same online bank, in special cases within milliseconds, potentially causing MitID to issue a so-called token to another session. This error could have been avoided if the broker (the company that facilitates the authentication response - in this case, Signaturgruppen) had validated citizens' logins using a technology called Broker Security Context. The Digitalization Agency, which is responsible for MitID, had recommended this but did not make it a requirement.

However, the Data Protection Agency assesses in the decision that it should have been a requirement - and concludes that the Digitalization Agency did not have sufficient measures in place to achieve a security level appropriate to the risks faced by citizens. At the same time, the Data Protection Agency believes that Signaturgruppen, as the data controller for the broker solution, also did not have appropriate security measures because they used Broker Security Context in a manner different from that described in the recommendation.

On this basis, the Data Protection Agency expresses serious criticism of both the Digitalization Agency and Signaturgruppen (below).

****Decision****

In January 2022, the Data Protection Agency received reports from several financial institutions using BEC as a data processor regarding breaches of personal data security related to MitID. Based on these reports, the Data Protection Agency requested further information from the Digitalization Agency and BEC. It was revealed that there had been a concurrency error in MitID, which meant that two individuals attempting to log into the same financial institution within the same milliseconds could risk being issued identical tokens, which were forwarded from MitID to the broker that established the connection between the financial institution and MitID.

BEC informed the Data Protection Agency in a statement that Signaturgruppen serves as the broker between BEC and MitID, which is why the Data Protection Agency requested a number of details from Signaturgruppen on March 16, 2022. On March 30, 2022, Signaturgruppen submitted a statement to the Data Protection Agency.

Based on this statement, the Data Protection Agency sent a request for further information to Signaturgruppen. Signaturgruppen then provided a new statement on May 16, 2022. On May 23, 2022, the Data Protection Agency sent yet another request for further information to Signaturgruppen. Signaturgruppen submitted such a statement on June 10, 2022.

1. **Decision**

After reviewing the case, the Data Protection Agency finds grounds to express serious criticism that

Signaturgruppen's processing of personal data has not been conducted in accordance with the rules in the General Data Protection Regulation [1] Article 32, Section 1. Below follows a detailed review of the case and a justification for the Data Protection Agency's decision.

It is noted that the agency has also made a decision today regarding the Digitalization Agency.

The Data Protection Agency found grounds to express serious criticism that the Digitalization Agency's processing of personal data was not conducted in accordance with the rules in the General Data Protection Regulation Article 32, Section 1, as the Data Protection Agency found that the Digitalization Agency should have made the implementation of Broker Security Context a mandatory requirement for brokers to MitID before January 10, 2022.

2. **Case Presentation**

It appears from the case that users in several instances have experienced logging into their online bank using MitID, after which they gained access to other and unrelated users' online banks.

Furthermore, it appears from the case that the incidents occurred due to a temporal overlap between the logins of two different users - i.e., within milliseconds - on the same service through Signaturgruppen's Nets eID Broker ("NeB Broker"). According to the information in the case, Signaturgruppen serves as the broker between BEC and MitID. In connection with the actual authentication of a user, a request is sent via the browser to the broker (Signaturgruppen), which, through the MitID usage model "Package," starts the MitID client. Thereafter, the MitID dialogue with the user is handled in a pop-up window, where communication is made towards the MitID core. Upon successful authentication, a response (token) is sent back to BEC via the broker, and the broker receives a confirmation that the authentication was successful along with the corresponding MitID UUID. The UUID is used as a lookup in BEC's Online Banking Administration database to grant access to the correct user. The response, which...

returned, can either be positive (containing UUID) or negative (containing "fail"). The Signature Group has stated that an incorrect MitID user ID (UUID) was returned in connection with the broker receiving approval of user authentication along with the associated user information, i.e., MitID user ID. The returned MitID user ID belonged in the specific cases to another user's login session, which was running simultaneously in another browser and with another user.

The concurrency issue arose, according to the Signature Group, in MitID's own business application, and because the Signature Group had mistakenly only partially implemented a MitID-recommended security measure. For these reasons, the concurrency issue was not detected by the Signature Group's application, which led to the Signature Group passing the error in MitID to the affected online banks.

It appears from the case information that the Agency for Digitization had communicated a set of "Broker Security Requirements" prior to the incidents, containing two groups of security measures – some mandatory and some recommended. The Signature Group has stated that prior to the incidents, it had implemented all mandatory security measures aimed at brokers. The Signature Group had attempted to implement a recommended measure "Broker Security Context," but had a flaw in the implementation. Broker Security Context included, among other things, a recommendation that the broker could detect session errors by validating the token received from the MitID core, provided that the process at start had been assigned a session ID and by checking whether the authentication response contains a value that is different from the value that the broker provided when the flow started.

It further appears that the security measure can be used to detect when the error occurs, regardless of other circumstances regarding matching broker or service provider IDs for different users attempting to log in at the same time. However, Broker Security Context assumes that the broker specifies the value when the flow is started. It was also recommended that the broker uses a random value with high entropy, as this reduces the risk of confusion of values. The Signature Group has stated that the company's implementation did not have sufficiently high entropy.

After the incident, the Signature Group has implemented the recommended security measures in NeB Broker, which prevent identical tokens from granting unauthorized access to services. According to the

Signature Group, the security measures would have prevented the breaches if they had been implemented correctly. The Signature Group has stated that the error was due to a human misreading of the recommendation by the development group at the Signature Group.

The Signature Group has documented tests and source code examples and undergone external code review and penetration testing, but the specific error only emerged during actual operation in interaction with MitID, when there was a lot of traffic on the solution. There were no load tests during the implementation process for MitID that included brokers and service providers.

Processing of authentication responses in MitID occurs in two overarching data flows called upstream and downstream. The downstream flow concerns the transmission of the authentication response. It is the Agency for Digitization that transmits data to the broker, who then forwards data to a service provider. The broker is an independent data controller for the processing and transmission of the data received from the MitID core, for which the Agency for Digitization is the data controller.

According to the Signature Group, brokers can use different models for implementing the authentication flow, including the package model, which the Signature Group uses. In the package model, the broker uses components for authentication with MitID, where the MitID client and backend are provided by the Agency for Digitization. In the package model, the broker must implement the security product provided by the Agency for Digitization, including the security measures that accompany this model.

In MitID, brokers process data points about authentication responses and risk data. The broker must only forward the information under the authentication response that is received from the Agency for Digitization. The error was in the MitID core, and it is the Signature Group's opinion that the error therefore only pertains to the authentication response. The role of the Signature Group was to forward information from the Agency for Digitization to a service provider, which resulted in the processing of incorrect data, as evidenced in relation to the concurrency problem, whereby users in several cases experienced logging into their online bank using MitID, after which they gained access to other and unrelated users' online banks.

3. Justification for the Data Protection Authority's Decision

The Data Protection Authority bases its decision on the explanation provided by the Signature Group, that a MitID-recommended security measure regarding the assignment of session IDs was not carried out with a sufficiently high entropy. The Data Protection Authority further establishes that in several cases, a concurrency issue arose that was not detected by the Signature Group's application, which led to the Signature Group passing the error from MitID to the affected online banks. This resulted in two individuals attempting to log into the same financial institution within the same milliseconds risking being issued identical tokens, which were forwarded from MitID to the broker that established the connection between the financial institution and MitID. Users have in several cases experienced logging into their netbank using MitID, after which they gained access to other and unrelated users' netbank.

3.1. Article 32 of the Data Protection Regulation

It follows from Article 32, paragraph 1 of the Data Protection Regulation that the data controller must take appropriate technical and organizational measures to ensure a level of security appropriate to the risks arising from the data controller's processing of personal data.

Thus, the data controller has an obligation to identify the risks that its processing poses to the data subjects and to ensure that appropriate security measures are implemented to protect the data subjects from these risks. The Data Protection Agency assumes – in accordance with the explanation provided by Signaturgruppen – that Signaturgruppen is the data controller for the processing of personal data that occurs in the broker solution.

It is the opinion of the Data Protection Agency that the requirement under Article 32 for appropriate security will generally imply that, as a data controller and broker to a technical login solution where personal data is processed, here MitID, one must ensure the correct implementation of recommended

security measures in order to avoid unauthorized access to personal data by unrelated parties. The Data Protection Agency finds that there is an increased risk profile when the login solution provides access to a netbank solution.

On this basis, the Data Protection Agency finds that Signaturgruppen should have implemented the security measure recommended by MitID in NeB Broker with a higher entropy. By failing to do so, Signaturgruppen has not taken appropriate organizational and technical measures to ensure a level of security appropriate to the risks associated with the processing of personal data, cf. Article 32, paragraph 1 of the Data Protection Regulation.

The Data Protection Agency therefore expresses serious criticism that Signaturgruppen's processing of personal data has not occurred in accordance with the rules in Article 32, paragraph 1 of the Data Protection Regulation.

In choosing a response, the Data Protection Agency has emphasized that there has been unauthorized access to personal data, at least concerning financial matters, and that this access has likely involved a significant risk to the rights or freedoms of the data subjects, and that sufficient technical and organizational measures had not been taken to prevent the breach. The Agency has further emphasized that this is a nationwide solution, the primary purpose of which is to validate the identification of individuals in order to provide access only to the information that they are entitled to access, including personal data. Furthermore, the Data Protection Agency has given weight to the fact that Signaturgruppen immediately after the incident implemented the recommended security measures in NeB Broker, which prevent identical tokens from granting unauthorized access to services.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).